

Procedura obsługi incydentów bezpieczeństwa i incydentów operacyjnych

Bank Przykładowy S.A., BP/PRO/07, wersja 2, obowiązuje od 1 marca 2024 r. do 31 marca 2025 r.

Oznaczenie	BP/PRO/07
Wersja	2
Właściciel	Departament Bezpieczeństwa
Zatwierdził	Zarząd Banku Przykładowego S.A.
Data zatwierdzenia	9 lutego 2024 r.
Obowiązuje od	1 marca 2024 r.
Obowiązuje do	31 marca 2025 r.

Historia zmian

Wersja	Data	Opis zmian
1	11 października 2022 r.	Wydanie pierwsze.
2	9 lutego 2024 r.	Aktualizacja postanowień procedury.

1. Cel

Celem procedury jest zapewnienie jednolitego, szybkiego i udokumentowanego sposobu postępowania w przypadku wystąpienia w Banku incydentu bezpieczeństwa lub incydentu operacyjnego, tak aby zminimalizować jego skutki dla Klientów, ciągłości działania Banku i bezpieczeństwa chronionych informacji.

Procedura określa w szczególności:

- 1) źródła zgłoszeń o incydentach oraz sposób ich przyjmowania w Rejestrze;
- 2) zasady klasyfikacji incydentów i nadawania im poziomu ważności;
- 3) skład i zadania Zespołu oraz podział ról w trakcie obsługi incydentu;
- 4) działania mające na celu ograniczenie rozprzestrzeniania się incydentu i usunięcie jego przyczyn;
- 5) zasady komunikacji z Klientami, z organem nadzoru oraz z podmiotami zewnętrznymi;
- 6) terminy zgłaszania incydentów poważnych oraz naruszeń ochrony danych osobowych;
- 7) zabezpieczanie materiału dowodowego, przywracanie działania usług i przegląd po incydencie;
- 8) zasady testowania procedury i prowadzenia ćwiczeń.

Procedura służy także realizacji obowiązków Banku wynikających z przepisów o usługach płatniczych, Prawa bankowego oraz przepisów o ochronie danych osobowych, a także

wymogów organu nadzoru w zakresie zarządzania ryzyka operacyjnego i ryzyka technologicznego.

2. Zakres stosowania

Procedurę stosuje się do każdego incydentu, który wpływa na systemy informatyczne, procesy, dane, lokale lub pracowników Banku. Dotyczy to także incydentów powstałych po stronie dostawców usług zewnętrznych, jeżeli wywołują one skutki w działalności Banku.

Procedura obejmuje incydenty następujących rodzajów:

- 1) incydenty bezpieczeństwa informacji, w szczególności:
 - a) nieuprawniony dostęp do systemów, danych lub rachunków Klientów;
 - b) złośliwe oprogramowanie, w tym oprogramowanie szkodzące dane w celu wymuszenia okupu;
 - c) ataki typu odmowa usługi na kanały elektroniczne Banku;
 - d) wyłudzenie danych uwierzytelniających Klientów lub pracowników (phishing, vishing, smishing);
- 2) incydenty operacyjne, w szczególności:
 - a) awarie systemów centralnych, w tym systemu centralnego CBS-PRZYKŁAD, oraz systemów rozliczeniowych;
 - b) niedostępność bankowości elektronicznej, bankomatów lub terminali płatniczych;
 - c) błędy w przetwarzaniu transakcji prowadzące do nieprawidłowych obciążeń lub uznań rachunków;
 - d) niedostępność kluczowych dostawców lub podwykonawców;
- 3) incydenty związane z bezpieczeństwem fizycznym, jeżeli mogą skutkować utratą informacji lub środków Klientów;
- 4) naruszenia ochrony danych osobowych.

Procedura obowiązuje wszystkich pracowników Banku, osoby świadczące pracę na podstawie umów cywilnoprawnych oraz pracowników podmiotów zewnętrznych, którzy mają dostęp do systemów lub danych Banku. Obowiązek zgłoszenia incydentu dotyczy każdej z tych osób, niezależnie od zajmowanego stanowiska.

Procedury nie stosuje się do rutynowych zgłoszeń serwisowych niewpływających na bezpieczeństwo lub ciągłość działania, które obsługuje się w trybie wsparcia użytkowników. Reklamacje Klientów rozpatruje się według odrębnych zasad; jeżeli reklamacja ujawnia incydent, pracownik postępuje zgodnie z niniejszą procedurą.

3. Podstawy prawne i dokumenty powiązane

Procedurę opracowano na podstawie przepisów powszechnie obowiązujących oraz regulacji wewnętrznych Banku.

1. Z przepisów powszechnie obowiązujących szczególne znaczenie mają:
 - 1) obowiązki dostawców usług płatniczych w zakresie bezpieczeństwa i zgłaszania

poważnych incydentów określa ustawa z dnia 19 sierpnia 2011 r. o usługach płatniczych (Dz. U. 2024 poz. 30);

- 2) wymogi dotyczące zarządzania ryzykiem, kontroli wewnętrznej i ciągłości działania banków wynikają z przepisów prawa bankowego — zob. ustawa z dnia 29 sierpnia 1997 r. – Prawo bankowe (Dz. U. 2024 poz. 1646);
 - 3) zasady postępowania w razie naruszenia ochrony danych osobowych określa ustawa z dnia 10 maja 2018 r. o ochronie danych osobowych (Dz. U. 2019 poz. 1781) oraz rozporządzenie Parlamentu Europejskiego i Rady (UE) 2016/679.
2. Dokumenty wewnętrzne, z którymi procedura jest powiązana, to:
- 1) polityka bezpieczeństwa informacji Banku;
 - 2) plan ciągłości działania oraz plany awaryjnego odtwarzania systemów;
 - 3) instrukcja zarządzania uprawnieniami i dostępem do systemów;
 - 4) procedura obsługi reklamacji Klientów;
 - 5) procedura obsługi wniosków osób, których dane dotyczą.

W razie rozbieżności między procedurą a przepisami powszechnie obowiązującymi lub wytycznymi organu nadzoru stosuje się te przepisy lub wytyczne, a właściciel procedury niezwłocznie wszczyna tryb jej zmiany.

4. Odpowiedzialności

Za obsługę incydentów w Banku odpowiadają jednostki i osoby wymienione poniżej. Zakres ich zadań dotyczy każdej fazy obsługi incydentu: od wykrycia po przegląd końcowy. Zadania pozostałych jednostek opisano w dalszych częściach procedury.

1. **Pracownik** każdej jednostki Banku:
 - 1) zgłasza każde zauważone zdarzenie wskazujące na incydent w terminie 30 minut od jego zauważenia;
 - 2) nie podejmuje na własną rękę działań naprawczych, które mogłyby zniekształcić ślady incydentu;
 - 3) stosuje się do poleceń Zespołu wydanych w trakcie obsługi incydentu.
2. **Kierownik jednostki organizacyjnej:**
 - 1) zapewnia znajomość procedury wśród podległych pracowników, w tym przeszkolenie nowych pracowników w terminie 30 dni od zatrudnienia;
 - 2) wyznacza osobę kontaktową do spraw incydentów w swojej jednostce;
 - 3) udostępnia pracowników i zasoby potrzebne do obsługi incydentu.
3. **Departament Bezpieczeństwa**, jako właściciel procedury:
 - 1) prowadzi Rejestr i nadzoruje jego kompletność;
 - 2) kieruje pracami Zespołu i wyznacza kierownika incydentu;
 - 3) dokonuje klasyfikacji incydentów i zatwierdza zmianę ich poziomu ważności;
 - 4) przygotowuje zawiadomienia dla organu nadzoru i koordynuje współpracę z zespołem CSIRT;
 - 5) odpowiada za aktualność procedury, testy i ćwiczenia.

4. **Departament Informatyki** odpowiada za techniczną obsługę incydentu: izolowanie systemów, analizę techniczną, usunięcie przyczyn i przywrócenie działania usług, a także za zabezpieczanie logów i obrazów systemów.
5. **Departament Zgodności** ocenia, czy incydent wymaga zawiadomienia organu nadzoru, opiniuje treść zawiadomień i monitoruje realizację zaleceń po incydencie.
6. **Inspektor Ochrony Danych** ocenia, czy incydent stanowi naruszenie ochrony danych osobowych, określa ryzyko dla osób, których dane dotyczą, oraz opracowuje zgłoszenie do organu ochrony danych i powiadomienia osób zainteresowanych.
1. **Właściciele systemów i procesów** odpowiadają za gotowość swoich systemów do obsługi incydentów oraz za współpracę z Zespołem w trakcie ich trwania.
W szczególności:
 - 1) utrzymują aktualny opis architektury systemu, jego zależności od innych systemów i dostawców oraz listę osób technicznie odpowiedzialnych za jego działanie;
 - 2) wskazują dla każdego systemu maksymalny dopuszczalny czas przestoju i maksymalną dopuszczalną utratę danych, a wartości te uzgadniają z Jednostką ciągłości działania co najmniej raz w roku;
 - 3) w ciągu godziny od wezwania udostępniają Zespołowi niezbędne dostępy, dzienniki zdarzeń i wiedzę specjalistyczną;
 - 4) akceptują decyzję o ponownym uruchomieniu systemu po incydencie po sprawdzeniu, że przyczyna została usunięta lub skutecznie ograniczona.
2. Właściciel systemu nie może samodzielnie zamknąć incydentu ani zmienić jego klasyfikacji; może jedynie wnioskować o to do Kierownika incydentu, przedstawiając uzasadnienie na piśmie.

Opiekun relacji z dostawcą odpowiada za przepływ informacji między Bankiem a dostawcą, którego usługa została dotknięta incydem lub który jest jego źródłem.
Opiekun:

- 1) zna aktualne dane kontaktowe dostawcy do spraw incydentów oraz zakres jego zobowiązań wynikających z umowy;
- 2) żąda od dostawcy bieżących informacji o przyczynach, zakresie i przewidywanym czasie usunięcia skutków incydentu;
- 3) dokumentuje przekazane przez dostawcę informacje i niezwłocznie przekazuje je Kierownikowi incydentu;
- 4) rozlicza po zakończeniu incydentu wykonanie zobowiązań dostawcy, w tym terminów powiadomienia Banku.

Jednostka komunikacji (Biuro Komunikacji Korporacyjnej) przygotowuje komunikaty dla Klientów, mediów i pracowników, uzgodnione z kierownikiem incydentu, a w sprawach prawnych — także z Jednostką prawną. Jednostka komunikacji jest jedynym podmiotem uprawnionym do kontaktu z mediami w sprawie incydentu.

Jednostka obsługi klienta (Departament Obsługi Klienta) przekazuje Klientom uzgodnione komunikaty, zbiera zgłoszenia Klientów dotyczące incydentu i przekazuje kierownikowi incydentu zbiorcze informacje o ich liczbie i charakterze, nie rzadziej niż w odstępach ustalonych w raporcie stanu.

Jednostka ciągłości (Biuro Ciągłości Działania) uruchamia plany ciągłości działania, gdy incydent zagraża realizacji kluczowych procesów, koordynuje przejście na tryb awaryjny oraz pilnuje wartości RTO i RPO.

Jednostka ryzyka (Departament Ryzyka) bierze pod uwagę dane o incydentach w ocenie ryzyka operacyjnego, ustala poziomy tolerancji ryzyka dla incydentów i przedstawia Zarządowi zbiorcze analizy strat poniesionych w wyniku incydentów.

5. Definicje

Użyte w procedurze określenia oznaczają:

- 1) **Bank** — Bank Przykładowy S.A.;
- 2) **Klient** — osoba, która zamierza korzystać z produktów lub usług Banku;
- 3) **Pracownik** — osoba zatrudniona w Banku, realizująca czynności objęte procedurą;
- 4) **Właściciel procedury** — komórka organizacyjna odpowiedzialna za jej aktualność i stosowanie;
- 5) **Dzień roboczy** — dzień od poniedziałku do piątku, z wyłączeniem dni ustawowo wolnych od pracy;
- 6) **Trwały nośnik** — nośnik umożliwiający zachowanie informacji w sposób dostępny do późniejszego wykorzystania;
- 7) **Placówka** — jednostka Banku obsługująca Klientów;
- 8) **Infolinia** — telefoniczny punkt obsługi Klientów, numer 800 000 001;
- 9) **Eskalacja** — przekazanie sprawy do jednostki lub osoby o wyższych uprawnieniach decyzyjnych.

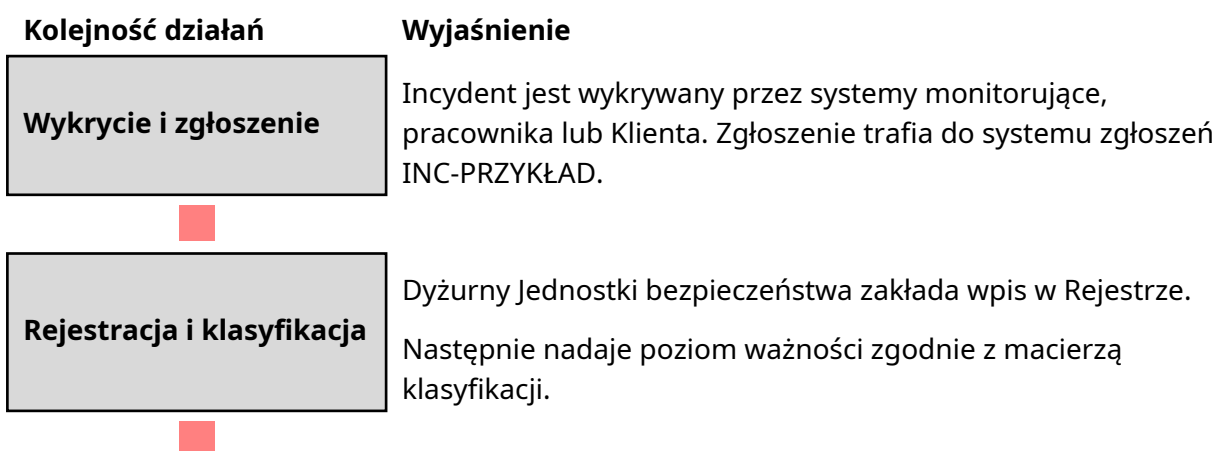
Na potrzeby procedury przyjmuje się dodatkowo następujące określenia:

- 1) **Incydent** — zdarzenie, które godzi w poufności, integralności lub dostępności informacji albo ciągłości działania usług, bądź jest uznawane o spowodowanie takiego naruszenia;
- 2) **Incydent bezpieczeństwa** — incydent związany z nieuprawnionym lub nieprawidłowym działaniem wobec informacji, systemów lub osób;
- 3) **Incydent operacyjny** — incydent wynikający z awarii, błędu lub zakłócenia procesów, systemów albo dostawców, niebędący działaniem celowym;
- 4) **Incydent poważny** — incydent o poziomie ważności krytycznym lub wysokim, spełniający kryteria zgłoszenia organowi nadzoru;
- 5) **Organ nadzoru** — organ nadzoru właściwy dla Banku, któremu przekazuje się zawiadomienia o incydentach poważnych;
- 6) **CSIRT** — zespół CSIRT właściwy dla sektora finansowego, z którym Bank wymienia informacje o zagrożeniach;
- 7) **Naruszenie ochrony danych osobowych** — naruszenie bezpieczeństwa prowadzące do przypadkowego lub bezprawnego zniszczenia, utraty, zmiany, nieuprawnionego ujawnienia danych osobowych lub dostępu do nich;
- 8) **Kierownik incydentu** — osoba wyznaczona przez Jednostkę bezpieczeństwa, która koordynuje obsługę konkretnego incydentu;

- 9) **Zespół** — Zespół Reagowania na Incydenty, złożony z przedstawicieli jednostek wskazanych w procedurze i powoływany do obsługi incydentów o poziomie wysokim i krytycznym;
- 10) **Rejestr** — centralny rejestr incydentów o nazwie RINC, prowadzony w systemie zgłoszeń INC-PRZYKŁAD;
- 11) **System SIEM** — system monitorowania zdarzeń SIEM-PRZYKŁAD, który zbiera i koreluje zdarzenia z systemów informatycznych;
- 12) **Pokój operacyjny** — wirtualny pokój operacyjny incydu, w którym prowadzi się dziennik zdarzeń i wymianę ustaleń podczas obsługi incydu;
- 13) **Jednostka bezpieczeństwa** — Departament Bezpieczeństwa; **Jednostka informatyki** — Departament Informatyki; **Jednostka zgodności** — Departament Zgodności; **Jednostka operacji** — Departament Operacji; **Jednostka prawna** — Departament Prawny;
- 14) **Jednostka komunikacji** — Biuro Komunikacji Korporacyjnej; **Jednostka obsługi klienta** — Departament Obsługi Klienta; **Jednostka ciągłości** — Biuro Ciągłości Działania; **Jednostka ryzyka** — Departament Ryzyka; **Jednostka audytu** — Departament Audytu Wewnętrznego; **Jednostka kadr** — Departament Zasobów Ludzkich;
- 15) **Inspektor** — Inspektor Ochrony Danych; **Zarząd** — Zarząd Banku;
- 16) **Ograniczenie skutków** — działania zatrzymujące rozprzestrzenianie się incydu bez usuwania jego przyczyny;
- 17) **Materiał dowodowy** — logi, obrazy dysków, zapisy rozmów, wiadomości i inne dane, które mogą służyć ustaleniu przebiegu incydu;
- 18) **RTO i RPO** — odpowiednio maksymalny akceptowalny czas przywrócenia usługi oraz maksymalna akceptowalna utrata danych, określone w planie ciągłości działania.

6. Opis postępowania — wykrywanie i rejestracja incydu

Poniższy schemat przedstawia podstawowy przebieg obsługi incydu. Szczegółowe zasady dla poszczególnych etapów opisano w dalszej części procedury.



Kolejność działań	Wyjaśnienie
Ograniczenie skutków	Zespół zatrzymuje rozprzestrzenianie się incyduentu i zabezpiecza ślady.
Komunikacja i raportowanie	Informowani są Klienci, kierownictwo, organ nadzoru oraz inne uprawnione podmioty w terminach określonych procedurą.
Usunięcie i przywrócenie	Usuwa się przyczynę incyduentu i przywraca działanie usług według priorytetów ciągłości działania.
Przegląd i wnioski	Po zamknięciu incyduentu przeprowadza się przegląd, a zalecenia wprowadza do planu działań.

6.1. Źródła wykrywania. Incydenty identyfikuje się na podstawie następujących źródeł:

- 6.1.1. alertów systemu SIEM (SIEM-PRZYKŁAD), który koreluje zdarzenia z systemów informatycznych, zapór sieciowych, systemów antywirusowych i systemów kontroli dostępu;
- 6.1.2. zgłoszeń pracowników przekazywanych przez system zgłoszeń INC-PRZYKŁAD, telefonicznie pod numerem dyżurnym 800 000 040 lub pocztą elektroniczną na adres incydenty@bank.example;
- 6.1.3. zgłoszeń Klientów przyjmowanych na infolinii 800 000 001, w placówkach i w reklamacjach;
- 6.1.4. komunikatów dostawców zewnętrznych, partnerów rozliczeniowych, zespołu CSIRT oraz organu nadzoru;
- 6.1.5. wyników kontroli, audytów, testów penetracyjnych i monitoringu transakcji pod kątem nadużyć.

6.2. Zgłoszenie przez pracownika. Pracownik, który zauważy zdarzenie mogące być incyduentem, zgłasza je w terminie 30 minut od jego zauważenia.

- 6.2.1. Zgłoszenie obejmuje opis zdarzenia, czas jego zauważenia, nazwę systemu lub procesu, liczbę i rodzaj podejrzanych operacji oraz dane osoby zgłaszającej; wzór zgłoszenia stanowi formularz F-BEZ-01.
- 6.2.2. Jeżeli zdarzenie może mieć skutki krytyczne (np. niedostępność systemu centralnego, wyciek danych, podejrzenie przejęcia kont uprzywilejowanych), pracownik najpierw dzwoni na numer dyżurny, a dopiero potem uzupełnia formularz.
- 6.2.3. Pracownik zachowuje wiadomość, plik lub zrzut ekranu, które wzbudziły podejrzenie, i nie przekazuje ich dalej poza kanały służbowe.

6.3. Przyjęcie zgłoszenia. Dyżurny Jednostki bezpieczeństwa przyjmuje zgłoszenie w systemie zgłoszeń, niezwłocznie potwierdza jego przyjęcie osobie zgłaszającej i weryfikuje kompletność zgłoszenia.

- 6.3.1. Gdy zgłoszenie jest niekompletne, dyżurny uzupełnia je w rozmowie z osobą zgłaszającą, nie wstrzymując rejestracji.
- 6.3.2. Zgłoszenia wielokrotne dotyczące tego samego zdarzenia łączy się w jeden wpis, zachowując ich historię.
- 6.4. Rejestracja incydentu. Dyżurny zakłada wpis w Rejestrze i przypisuje mu unikalny numer. Do wpisu wprowadza się co najmniej:
 - 6.4.1. datę i godzinę wykrycia oraz zgłoszenia, a także źródło informacji;
 - 6.4.2. opis zdarzenia i systemy lub procesy, których dotyczy;
 - 6.4.3. wstępną ocenę skutków, w tym liczbę Klientów i wartość operacji objętych incydem;
 - 6.4.4. imię i nazwisko osoby odpowiedzialnej za dalszą obsługę oraz kartę incydentu według formularza F-BEZ-02.
- 6.5. Wstępna weryfikacja. Dyżurny sprawdza w ciągu kilkunastu minut, czy zdarzenie rzeczywiście jest incydem, a nie fałszywym alarmem. Fałszywy alarm zamyka się z adnotacją o przyczynie; wpis pozostaje w Rejestrze.
- 6.6. Powiadomienie dyżurnych. Przy zdarzeniach, które mogą mieć poziom wysoki lub krytyczny, dyżurny niezwłocznie powiadamia kierownika Jednostki bezpieczeństwa i dyżurnego Jednostki informatyki.
- 6.7. Monitoring transakcji. Jednostka bezpieczeństwa prowadzi monitoring transakcji pod kątem nadużyć, korzystając z reguł wykrywania wzorców charakterystycznych dla oszustw płatniczych, takich jak:
 - 6.7.1. seria transakcji o nietypowych wartościach lub w krótkich odstępach czasu;
 - 6.7.2. logowanie z nowych urządzeń lub lokalizacji, połączone z szybką zmianą danych kontaktowych Klienta;
 - 6.7.3. nagłe podwyższenie limitów, po którym następują wypłaty lub przelewy na nowe rachunki;
 - 6.7.4. zbieżność wielu transakcji na ten sam rachunek odbiorcy, co może wskazywać na rachunek wykorzystywany do wyprowadzania środków.
- 6.8. Postępowanie po alarmie. Gdy reguła wykryje podejrzaną transakcję, analityk w pierwszej kolejności blokuje jej realizację, o ile pozwala na to system, a następnie kontaktuje się z Klientem kanałem zgodnym z danymi zapisanymi w Banku, aby potwierdzić autentyczność operacji.
- 6.9. Przekazanie do Jednostki zgodności. Jeżeli podejrzenie nadużycia wskazuje również na ryzyko prania pieniędzy, analityk przekazuje sprawę Jednostce zgodności, nie informując Klienta o możliwym zgłoszeniu transakcji do właściwych organów — zob. ustawa z dnia 1 marca 2018 r. o przeciwdziałaniu praniu pieniędzy oraz finansowaniu terroryzmu (Dz. U. 2025 poz. 644).
- 6.10. Dyżury i dostępność. Jednostka bezpieczeństwa i Jednostka informatyki zapewniają dyżury w trybie całodobowym. Harmonogram dyżurów jest dostępny w systemie zgłoszeń i przekazywany dyżurnym telefonicznie na początku każdego miesiąca.
- 6.11. Zasady dyżuru poza godzinami pracy. Dyżurny poza godzinami pracy:
 - 6.11.1. jest osiągalny pod numerem służbowym i podejmuje zgłoszenie w czasie

pierwszej reakcji właściwym dla poziomu ważności;

6.11.2. ma zdalny dostęp do Rejestru i systemu SIEM oraz aktualną listę kontaktów alarmowych;

6.11.3. w przypadku niemożności objęcia dyżuru bez zbędnej zwłoki powiadamia kierownika Jednostki bezpieczeństwa, który wyznacza zastępstwo.

6.12. Lista kontaktów alarmowych. Lista kontaktów alarmowych obejmuje numery służbowe członków Zespołu, dyrektorów jednostek, kluczowych dostawców, zespołu CSIRT i organu nadzoru. Lista jest przechowywana również w postaci papierowej w zabezpieczonym miejscu, tak aby była dostępna w razie niedostępności systemów.

Wykrywanie incydentów opiera się nie tylko na zgłoszeniach pracowników, lecz także na ciągłym monitorowaniu systemów. Podstawowym narzędziem monitorowania jest system SIEM-PRZYKŁAD, do którego trafiają dzienniki zdarzeń z kluczowych systemów Banku.

6.13. Reguły korelacji zdarzeń. Jednostka bezpieczeństwa prowadzi zbiór reguł, które automatycznie podnoszą alert po wykryciu niepokojącego wzorca.

6.13.1. Reguły obejmują co najmniej serię nieudanych logowań, logowanie z nietypowej lokalizacji lub o nietypowej porze, nagłe zwiększenie liczby pobrań danych oraz zmiany uprawnień kont uprzywilejowanych.

6.13.2. Każdą regułę opisuje się w katalogu reguł: podaje się jej cel, źródła danych, próg uruchomienia, osobę odpowiedzialną i datę ostatniego przeglądu.

6.13.3. Reguły przegląda się co najmniej raz na pół roku oraz po każdym incydencie, który nie został wykryty automatycznie.

6.14. Obsługa alertów. Każdy alert wygenerowane przez system monitorowania jest przydzielane analitykowi dyżurnemu i wymaga rozstrzygnięcia.

6.14.1. Analityk ocenia alert w ciągu 2 godzin i oznacza go jako prawdziwy incydent, zdarzenie do dalszej obserwacji albo alarm fałszywy.

6.14.2. Alarm fałszywy uzasadnia się w notatce, a powtarzające się alarmy fałszywe są podstawą do zmiany progu reguły.

6.14.3. Alert oznaczony jako prawdziwy incydent jest rejestrowany zgodnie z zasadami opisanymi w kolejnych punktach.

6.15. Weryfikacja ciągłości monitorowania. Jednostka bezpieczeństwa codziennie sprawdza, czy wszystkie źródła dzienników przesyłają dane; brak danych ze źródła przez ponad godzinę traktuje się jako zdarzenie wymagające wyjaśnienia.

6.16. Podatności i zdarzenia wykryte w testach. Zdarzenia, w których test penetracyjny, skan podatności lub audyt wykażą możliwość nieuprawnionego dostępu do danych Klientów, ocenia Jednostka bezpieczeństwa pod kątem tego, czy podatność została już wykorzystana.

6.16.1. Gdy istnieją ślady wykorzystania podatności, zdarzenie rejestruje się jako incydent i klasyfikuje według zasad ogólnych.

6.16.2. Jeżeli brak takich śladów, podatność ujmuje się w rejestrze podatności i usuwa w terminie zależnym od jej krytyczności, a Rejestr zawiera odniesienie do decyzji o nierejestrowaniu incydentu.

6.17. Informacje z zewnątrz. Ostrzeżenia o nowych zagrożeniach otrzymane od zespołu

CSIRT, producentów oprogramowania lub z publicznych źródeł Jednostka bezpieczeństwa porównuje z zasobami Banku i w przypadku potrzeby inicjuje działania zapobiegawcze, zanim dojdzie do incydentu.

7. Opis postępowania — klasyfikacja i ocena incydentu

Klasyfikacja incydentu służy ustaleniu wymaganego czasu reakcji, składu zespołu obsługującego incydent i zakresu zawiadomień. Poziom ważności określa się na podstawie najpoważniejszego ze skutków wskazanych w tabeli. Pełną macierz klasyfikacji zawiera Załącznik nr 1.

Poziom ważności	Kryteria (wystarczy spełnienie jednego)	Pierwsza reakcja — do
Krytyczny	incydent dotyczy ponad 1 000 Klientów, albo niedostępność kluczowej usługi trwa dłużej niż 2 godziny, albo potencjalna strata przekracza 500 000,00 zł, albo doszło do naruszenia danych o wysokim ryzyku	15 minut
Wysoki	incydent dotyczy od 100 do 1 000 Klientów, albo niedostępność usługi trwa od 30 minut do 2 godzin, albo potencjalna strata przekracza 50 000,00 zł	1 godziny
Średni	ograniczone zakłócenie jednego procesu lub kanału, bez wpływu na rozliczenia, z istniejącym obejściem	4 godzin
Niski	zdarzenie bez wpływu na Klientów i procesy, zablokowane w całości przez zabezpieczenia	2 dni roboczych

7.1. Ocena wstępna. Dyżurny Jednostki bezpieczeństwa dokonuje wstępnej klasyfikacji w ciągu 2 godzin od zarejestrowania zgłoszenia.

7.1.1. Klasyfikacja obejmuje ocenę wpływu na poufność, integralność i dostępność informacji, liczbę dotkniętych Klientów, wartość operacji i ryzyko dla reputacji Banku.

7.1.2. Gdy dane są niepełne, przyjmuje się poziom wyższy; obniżenie poziomu jest możliwe dopiero po uzyskaniu pełnych danych.

7.2. Ustalenie rodzaju incydentu. Dyżurny przypisuje incydent do kategorii: złośliwe oprogramowanie, nieuprawniony dostęp, odmowa usługi, wyłudzenie danych, wyciek danych, awaria systemu, błąd przetwarzania, incydent dostawcy lub incydent fizyczny. Kategoria wpływa na doborze członków Zespołu.

7.3. Ocena obowiązków zewnętrznych. Jednostka zgodności oraz Inspektor oceniają, czy incydent:

7.3.1. spełnia kryteria incydentu poważnego i wymaga zawiadomienia organu nadzoru;

7.3.2. stanowi naruszenie ochrony danych osobowych wymagające zgłoszenia do organu ochrony danych lub powiadomienia osób, których dane dotyczą;

7.3.3. wymaga zawiadomienia organów ścigania lub innych uprawnionych instytucji.

7.4. Powołanie Zespołu. Incydent o poziomie wysokim lub krytycznym obsługuje Zespół, którego kierownikiem jest wyznaczony przedstawiciel Jednostki bezpieczeństwa. Dla incydentów średnich i niskich obsługę prowadzi dyżurny wraz z właściwą jednostką.

- 7.5. Zmiana poziomu ważności. Poziom ważności może zostać zmieniony w trakcie obsługi, jeżeli pojawią się nowe informacje. Zmianę wraz z uzasadnieniem i godziną odnotowuje się w Rejestrze; podwyższenie poziomu uruchamia obowiązki właściwe dla nowego poziomu od chwili zmiany.
- 7.6. Eskalacja. Incydent krytyczny kierownik Jednostki bezpieczeństwa niezwłocznie zgłasza członkowi Zarządu nadzorującemu ryzyko; incydent wysoki — dyrektorom departamentów dotkniętych incydem.

Klasyfikacja nadana w chwili zgłoszenia ma charakter wstępny i podlega weryfikacji wraz z napływem nowych informacji. Zmiana klasyfikacji w górę lub w dół jest normalnym elementem obsługi incydem.

- 7.7. Podwyższenie klasyfikacji. Kierownik incydem podwyższa klasyfikację niezwłocznie po stwierdzeniu, że spełniona jest przesłanka wyższego poziomu.
 - 7.7.1. Zmianę zapisuje się w karcie incydem z podaniem godziny, przyczyny i osoby podejmującej decyzję.
 - 7.7.2. Podwyższenie klasyfikacji powoduje uruchomienie czasów reakcji właściwych dla nowego poziomu, liczonych od chwili zmiany.
 - 7.7.3. O zmianie informuje się osoby i jednostki, które według macierzy komunikacji powinny być powiadamiane na wyższym poziomie.
- 7.8. Obniżenie klasyfikacji. Obniżenie wymaga zgody osoby, która nadała poprzednią klasyfikację, lub — dla incydentów krytycznych — zgody członka Zarządu odpowiedzialnego za bezpieczeństwo.
 - 7.8.1. Obniżenie nie może być dokonane tylko dlatego, że upłynął znaczny czas od zdarzenia; musi wynikać z ustalenia, że skutki są mniejsze, niż pierwotnie zakładano.
 - 7.8.2. Kierownik incydem odnotowuje, które zobowiązania z wyższego poziomu pozostają do wykonania mimo obniżenia klasyfikacji.
- 7.9. Spory o klasyfikację. W razie rozbieżności stanowisk między jednostkami przyjmuje się klasyfikację wyższą do czasu rozstrzygnięcia sporu przez Komitet nadzorujący bezpieczeństwo.

Incydenty powiązane ze sobą należy oceniać łącznie. Seria pozornie drobnych zdarzeń może wskazywać na zaplanowany atak, którego skutki są znacznie poważniejsze niż skutki każdego ze zdarzeń z osobna.

- 7.10. Wyszukiwanie powiązań. Przy rejestracji nowego incydem analityk przeszukuje rejestr RINC pod kątem zdarzeń z ostatnich dziewięćdziesięciu dni dotyczących tych samych systemów, kont, adresów sieciowych, dostawców lub metod ataku.
- 7.11. Łączenie incydentów. Jeżeli powiązanie jest prawdopodobne, analityk zakłada incydent nadrzędny i podcina do niego zdarzenia powiązane.
 - 7.11.1. Klasyfikację incydem nadrzędnego ustala się na podstawie łącznych skutków wszystkich zdarzeń.
 - 7.11.2. Zdarzenia podpięte nie są zamykane, dopóki nie zostanie zamknięty incydent nadrzędny.

- 7.12. Rozdzielanie incydentów. Jeżeli w toku analizy okaże się, że zdarzenia nie są powiązane, rozdziela się je ponownie, a każde ocenia osobno z zachowaniem historii wpisów.
- 7.13. Informacja o powiązaniach. Powiązania i ich uzasadnienie opisuje się w karcie incydu, aby przy przeglądzie można było ocenić trafność decyzji.
- 7.14. Kategorie szczegółowe. Przy rejestracji incydu wskazuje się kategorię główną i, gdy to możliwe, podkategorię. Przyjęto następujące kategorie główne:
- 7.14.1. złośliwe oprogramowanie — wirusy, trojany, oprogramowanie szyfrujące i szpiegujące;
 - 7.14.2. nieuprawniony dostęp — przejęcie konta, obejście uwierzytelniania, nadużycie uprawnień;
 - 7.14.3. odmowa usługi — celowe przeciążenie systemów lub sieci;
 - 7.14.4. wyłudzenie danych — wiadomości lub rozmowy, w których sprawca podszywa się pod Bank lub Klienta;
 - 7.14.5. wyciek danych — ujawnienie danych osobom nieuprawnionym;
 - 7.14.6. awaria — niezamierzona niedostępność lub nieprawidłowe działanie systemu;
 - 7.14.7. błąd przetwarzania — nieprawidłowe zaksięgowanie, naliczenie lub przekazanie operacji;
 - 7.14.8. incydent dostawcy — incydent po stronie podmiotu zewnętrznego wpływający na usługi Banku;
 - 7.14.9. incydent fizyczny — kradzież, włamanie, pożar, zalanie lub inne zdarzenie w lokalu.
- 7.15. Zmiana kategorii. Kategorię można zmienić po uzyskaniu nowych informacji; zmianę odnotowuje się w Rejestrze, a pierwotną kategorię zachowuje się w historii wpisu.
- 7.16. Ocena ryzyka naruszenia danych. Inspektor ocenia ryzyko dla osób, których dane dotyczą, uwzględniając:
- 7.16.1. rodzaj i wrażliwość danych (dane identyfikacyjne, finansowe, dane szczególnych kategorii);
 - 7.16.2. liczbę osób i łatwość ich identyfikacji na podstawie ujawnionych danych;
 - 7.16.3. zakres zabezpieczeń zastosowanych do danych, zwłaszcza szyfrowanie, które mogłoby uniemożliwić zapoznanie się z nimi;
 - 7.16.4. prawdopodobne skutki dla osób, takie jak kradzież tożsamości, strata finansowa, dyskryminacja lub naruszenie dobrego imienia.
- 7.17. Dokumentowanie oceny. Wynik oceny, wraz z uzasadnieniem, Inspektor wpisuje do Rejestru, także wtedy, gdy uznaje, że zgłoszenie do organu ochrony danych nie jest wymagane.

8. Opis postępowania — reagowanie i ograniczanie skutków

- 8.1. Uruchomienie Zespołu. Kierownik incydu zwołuje Zespół w czasie pierwszej reakcji właściwym dla poziomu ważności i otwiera pokój operacyjny, w którym prowadzi się chronologiczny zapis ustaleń i decyzji.

- 8.1.1. Każdy członek Zespołu potwierdza gotowość i podaje zakres swoich działań.
 - 8.1.2. Kierownik incydentu przydziela zadania i wyznacza osobę prowadzącą dziennik zdarzeń.
 - 8.2. Ocena zakresu. Jednostka informatyki ustala, które systemy, dane i konta są dotknięte incydem, od kiedy i w jaki sposób do niego doszło, oraz czy incydent trwa.
 - 8.3. Ograniczenie skutków. Zespół podejmuje działania zatrzymujące rozprzestrzenianie się incydentu, dobierając je do rodzaju zdarzenia:
 - 8.3.1. odłączenie zainfekowanych stacji i segmentów od sieci Banku bez wyłączania zasilania (aby zachować zawartość pamięci);
 - 8.3.2. zablokowanie lub zmiana danych uwierzytelniających przejętych kont, tokenów i certyfikatów;
 - 8.3.3. zablokowanie złośliwych adresów, domen i nadawców wiadomości na urządzeniach brzegowych;
 - 8.3.4. czasowe wyłączenie podatnej funkcji lub kanału, jeżeli jest to proporcjonalne do ryzyka;
 - 8.3.5. wstrzymanie wypłat lub zleceń płatniczych objętych podejrzeniem nadużycia, w uzgodnieniu z Jednostką operacji.
 - 8.4. Decyzje o wyłączeniu usług. Decyzję o wyłączeniu kanału lub usługi dla Klientów podejmuje kierownik incydentu w porozumieniu z dyrektorem Jednostki operacji; w przypadku incydentu krytycznego powiadamia się o niej członek Zarządu. Wyłączenie ma trwać jak najkrócej, a jego przyczyny, czas i zakres odnotowuje się w dzienniku zdarzeń.
 - 8.5. Zabezpieczenie dowodów przed naprawą. Zanim wykona się czynności zmieniające stan systemów (restart, reinstalacja, czyszczenie), zabezpiecza się materiał dowodowy zgodnie z zasadami opisanymi w dalszej części procedury.
 - 8.6. Usunięcie przyczyny. Po ograniczeniu skutków Zespół usuwa przyczynę incydentu:
 - 8.6.1. usuwa złośliwe oprogramowanie i wszelkie mechanizmy trwałej obecności atakującego;
 - 8.6.2. instaluje poprawki i zmienia konfigurację, które umożliwiły incydent;
 - 8.6.3. sprawdza, czy w innych systemach nie występują te same słabości;
 - 8.6.4. dokumentuje wykonane czynności w karcie incydentu.
 - 8.7. Raport stanu. Kierownik incydentu przygotowuje cykliczny raport stanu: dla incydentu krytycznego co godzinę, dla wysokiego — co cztery godziny. Raport obejmuje status, podjęte działania, planowane czynności i szacowany czas przywrócenia usług.
- Incydent operacyjny polegający na błędnym przetworzeniu transakcji wymaga od Banku szybkiego ustalenia skutków dla klientów oraz naprawienia błędu zgodnie z zasadami rozliczeń.
- 8.8. Zatrzymanie przetwarzania. Właściciel procesu wstrzymuje dalsze przetwarzanie transakcji dotkniętych błędem, aby nie powiększać liczby błędnych operacji.
 - 8.9. Ustalenie zakresu. Jednostka operacji, Departament Operacji, sporządza wykaz wszystkich operacji dotkniętych błędem, z podaniem kwot, rachunków i dat

księgowania.

- 8.9.1. Wykaz weryfikuje druga osoba, niezależna od osoby, która go przygotowała.
- 8.9.2. Operacje, w których środki opuściły Bank, wyodrębnia się i traktuje priorytetowo.
- 8.10. Naprawa błędu. Korekty księgowania dokonuje się na podstawie polecenia podpisanego przez Kierownika incyduentu i kierownika właściwej jednostki operacyjnej, w trybie podwójnej kontroli.
- 8.11. Zwrot środków klientom. Klientom, którzy ponieśli stratę lub których rachunki obciążono nienależnie, zwraca się środki bez konieczności składania reklamacji, w terminie do końca następnego dnia roboczego, a w razie utraty odsetek lub opłat — również odpowiednie koszty.
- 8.12. Informacja dla klientów. Klienci otrzymują wyjaśnienie błędu i zapewnienie o jego usunięciu, a Jednostka obsługi klienta zostaje poinformowana o treści wyjaśnienia, aby udzielać spójnych odpowiedzi.
- 8.13. Współpraca z wyspecjalizowanymi podmiotami. Gdy Bank nie dysponuje wystarczającymi zasobami do analizy lub usunięcia skutków incyduentu, kierownik incyduentu może za zgodą dyrektora Jednostki bezpieczeństwa skorzystać ze wsparcia zewnętrznego zespołu specjalistów, z którym Bank ma zawartą umowę ramową.
 - 8.13.1. Umowa z zewnętrznym zespołem obejmuje klauzule poufności i zapewnia, że zespół działa pod nadzorem Banku.
 - 8.13.2. Dostęp zespołu do systemów i danych ogranicza się do niezbędnego zakresu i rejestruje.
 - 8.13.3. Wyniki analizy zespół przekazuje jedynie Bankowi.
- 8.14. Tryb awaryjny. Jeżeli przywrócenie usługi w czasie wynikającym z RTO nie jest możliwe, kierownik incyduentu wraz z Jednostką ciągłości wnioskuje do członka Zarządu o uruchomienie planu ciągłości działania.
 - 8.14.1. Plan ciągłości działania uruchamia się decyzją członka Zarządu nadzorującego operacje lub osoby przez niego upoważnionej; decyzję odnotowuje się w dzienniku zdarzeń.
 - 8.14.2. W trybie awaryjnym placówki obsługują Klientów według uproszczonych zasad i w ograniczonym zakresie czynności, zgodnie z planem.
 - 8.14.3. Operacje wykonane w trybie awaryjnym oznacza się i po przywróceniu systemów rekonsyliuje z danymi systemu centralnego CBS-PRZYKŁAD.
- 8.15. Zmiany w systemach w trakcie incyduentu. Zmiany w systemach dokonywane w trakcie obsługi incyduentu (poprawki, zmiany konfiguracji, wyłączenia) wymagają zgody kierownika incyduentu i są odnotowywane w dzienniku zdarzeń. Procedura zarządzania zmianą w trybie przyspieszonym obejmuje następujące uproszczenia:
 - 8.15.1. zgodę na zmianę wydaje kierownik incyduentu zamiast zwykłego komitetu zmian;
 - 8.15.2. dokumentację zmiany uzupełnia się nie później niż w terminie 7 dni po zamknięciu incyduentu;
 - 8.15.3. zmiany niekonieczne do ograniczenia skutków odkłada się do czasu zakończenia incyduentu.

9. Opis postępowania — komunikacja i raportowanie

Komunikację w trakcie incydentu prowadzi się jedynie według zasad poniżej. Pracownicy nieupoważnieni do kontaktu z mediami, Klientami lub instytucjami zewnętrznymi nie udzielają informacji o incydencie i kierują wszelkie pytania do Jednostki komunikacji.

- 9.1. Komunikacja wewnętrzna. Kierownik incydentu informuje o incydencie osoby i jednostki, które muszą podjąć działania, w zakresie koniecznym do ich wykonania.
 - 9.1.1. Informacje o incydentach krytycznych i wysokich przekazuje się w pokoju operacyjnym, a gdy ten jest niedostępny — telefonicznie.
 - 9.1.2. Pracownikom placówek i infolinii przekazuje się krótką instrukcję: co wiadomo, co mówić Klientom i dokąd kierować pytania.
 - 9.1.3. Informacje o przyczynach i sprawcach incydentu nie są przekazywane pracownikom spoza Zespołu do czasu zakończenia analizy.
- 9.2. Komunikacja z Klientami. Jeżeli incydent dotyczy Klientów, Jednostka komunikacji przygotowuje komunikat, który:
 - 9.2.1. w prosty sposób informuje, czego incydent dotyczy i jakich usług lub produktów;
 - 9.2.2. wskazuje zalecane działania Klienta (np. zmiana hasła, unikanie wskazanych linków) oraz numer infolinii 800 000 001;
 - 9.2.3. nie zawiera szczegółów technicznych, które mogłyby ułatwić dalsze ataki;
 - 9.2.4. przypomina, że Bank nie prosi o podanie pełnych danych uwierzytelniających.
- 9.3. Termin powiadomienia Klientów. Klientów, których dotyczy incydent o wysokim ryzyku dla ich środków lub danych, powiadamia się w terminie 24 godzin od potwierdzenia, że incydent ich dotyczy. Gdy tożsamość dotkniętych Klientów nie jest jeszcze znana, zamieszcza się komunikat ogólny w bankowości elektronicznej i na stronie <https://bank.example>.

Incydenty poważne oraz naruszenia ochrony danych osobowych podlegają zgłoszeniu w terminach określonych poniżej. Terminy liczy się w godzinach, a nie w dniach roboczych — obejmują one dni ustawowo wolne od pracy, noce i weekendy.

- 9.4. Kwalifikacja incydentu poważnego. Jednostka zgodności wspólnie z Jednostką bezpieczeństwa ustala, czy incydent jest incydemtem poważnym. Przy ocenie uwzględnia się zwłaszcza liczbę dotkniętych Klientów, czas trwania, zasięg, wartość transakcji, wpływ na inne instytucje i skutki dla reputacji Banku. Decyzję odnotowuje się w Rejestrze.
- 9.5. Zawiadomienie wstępne. Zawiadomienie wstępne dla organu nadzoru przekazuje się w ciągu 6 godzin od zaklasyfikowania incydentu jako poważnego, a w każdym razie nie później niż w terminie 24 godzin od momentu, w którym Bank dowiedział się o incydencie.
 - 9.5.1. Zawiadomienie przygotowuje Jednostka bezpieczeństwa na formularzu F-BEZ-06, a opiniuje Jednostka zgodności.
 - 9.5.2. Zawiadomienie zawiera dane Banku, datę i godzinę wykrycia, wstępny opis incydentu, szacowany zasięg i rodzaj dotkniętych usług, informację o podjętych działaniach i dane osoby kontaktowej.

- 9.5.3. Zawiadomienie przekazuje się bezpiecznym kanałem wskazanym przez organ nadzoru; brak pełnych danych nie jest powodem opóźnienia — uzupełnia się je w zawiadomieniach kolejnych.
- 9.6. Zawiadomienie pośrednie. Zawiadomienie pośrednie przekazuje się w terminie 72 godzin od zawiadomienia wstępnego albo niezwłocznie po istotnej zmianie stanu incydentu, jeżeli nastąpi ona wcześniej.
- 9.6.1. Zawiadomienie pośrednie zawiera zaktualizowany opis incydentu, ustaloną przyczynę (jeśli jest znana), liczbę dotkniętych Klientów, wartość operacji, podjęte działania naprawcze i przewidywany czas przywrócenia usług.
- 9.6.2. Kolejne aktualizacje przekazuje się w miarę potrzeb, aż do zakończenia incydentu.
- 9.7. Raport końcowy. Raport końcowy przekazuje się w terminie 1 miesiąca od zawiadomienia pośredniego albo od ustania incydentu, zależnie od tego, które zdarzenie nastąpi później. Raport według formularza F-BEZ-03 obejmuje analizę przyczyny źródłowej, pełne skutki, wykonane i planowane środki zaradcze oraz informacje o ewentualnych kosztach.
- 9.8. Naruszenie ochrony danych osobowych — zgłoszenie. Jeżeli Inspektor stwierdzi, że naruszenie może skutkować ryzykiem naruszenia praw lub wolności osób fizycznych, Bank zgłasza je organowi ochrony danych bez zbędnej zwłoki, w miarę możliwości nie później niż w terminie 72 godzin od stwierdzenia naruszenia. Zgłoszenie dokonane po tym terminie wymaga wyjaśnienia przyczyn opóźnienia.
- 9.8.1. Zgłoszenie obejmuje charakter naruszenia, kategorie i przybliżoną liczbę osób oraz rekordów, dane kontaktowe Inspektora (iod@bank.example), możliwe skutki oraz środki zastosowane lub proponowane.
- 9.8.2. Podstawę prawną zgłoszenia stanowią przepisy o ochronie danych osobowych — zob. ustawa z dnia 10 maja 2018 r. o ochronie danych osobowych (Dz. U. 2019 poz. 1781).
- 9.9. Naruszenie ochrony danych osobowych — powiadomienie osób. Jeżeli naruszenie może powodować wysokie ryzyko naruszenia praw lub wolności osób, których dane dotyczą, Inspektor wspólnie z Jednostką komunikacji przygotowuje powiadomienie tych osób, napisane prostym językiem, i przekazuje je bez zbędnej zwłoki.
- Incydent może mieć wpływ na podmioty współpracujące z Bankiem. Informowanie ich o incydencie ma na celu ograniczenie skutków w ich systemach i umożliwienie wykonania ich własnych obowiązków.
- 9.10. Wskazanie kontrahentów do powiadomienia. Kierownik incydentu wraz z właścicielem procesu ustala, które podmioty zewnętrzne mogły zostać dotknięte incydem lub mogą pomóc w jego usunięciu.
- 9.10.1. Do takich podmiotów należą w szczególności dostawcy usług informatycznych, operatorzy płatności, banki korespondenckie oraz podmioty, którym Bank powierzył przetwarzanie danych.
- 9.10.2. Zakres przekazywanych informacji ogranicza się do tych, które są niezbędne do zabezpieczenia interesów stron.
- 9.11. Umowy o zachowaniu poufności. Informacji o incydencie nie przekazuje się podmiotom, które nie są związane obowiązkiem poufności wobec Banku.

- 9.12. Dokumentowanie powiadomień. Każde powiadomienie kontrahenta rejestruje się z podaniem daty, godziny, adresata, osoby przekazującej informację i jej zakresu.
- 9.13. Obowiązki kontrahentów. Wobec podmiotów, które na mocy umowy są obowiązane informować Bank o incydentach, Kierownik incydentu ocenia terminowość i kompletność ich powiadomień.
- 9.14. Komunikacja z dostawcami i partnerami. Dostawców, których usługi są dotknięte incydem lub mogą być jego przyczyną, kontaktuje kierownik incydentu według kanałów wskazanych w umowach.
 - 9.14.1. Każdą rozmowę z dostawcą odnotowuje się w dzienniku zdarzeń.
 - 9.14.2. Informacje przekazywane dostawcy ogranicza się do niezbędnych do rozwiązania problemu; dane Klientów nie są przekazywane bez podstawy prawnej i umowy powierzenia.
 - 9.14.3. Jeżeli dostawca nie reaguje w uzgodnionym czasie, kierownik incydentu eskaluje sprawę do osoby kierującej relacją z dostawcą i powiadamia dyrektora Jednostki bezpieczeństwa.

Komunikacja wewnątrz Banku ma zapewnić, że pracownicy mają spójną i aktualną wiedzę o incydencie, a jednocześnie nie rozpowszechniają niepotwierdzonych informacji.

- 9.15. Komunikat dla pracowników. Jeżeli incydent może wpływać na codzienną pracę pracowników, Kierownik incydentu wraz z Jednostką komunikacji przygotowuje komunikat wewnętrzny.
 - 9.15.1. Komunikat zawiera krótki opis sytuacji, polecenia dla pracowników (na przykład zakaz otwierania określonych wiadomości) oraz dane kontaktowe do uzyskania pomocy.
 - 9.15.2. Komunikat nie zawiera szczegółów technicznych ani informacji o ustaleniach, które mogłyby ułatwić sprawcom dalsze działanie.
- 9.16. Informacje dla placówek i infolinii. Pracownicy mający kontakt z klientami otrzymują ustalone odpowiedzi na najczęstsze pytania.
 - 9.16.1. Odpowiedzi aktualizuje się na bieżąco, a wersje oznacza godziną opublikowania.
 - 9.16.2. Pracownik, który nie zna odpowiedzi, nie udziela informacji domysłów, lecz kieruje pytanie do wyznaczonej osoby.
- 9.17. Zakaz wypowiedzi publicznych. Pracownicy nie udzielają informacji mediom ani nie zamieszczają jej w mediach społecznościowych; wszystkie zapytania przekazują do Jednostki komunikacji.
- 9.18. Zamknięcie komunikacji. Po zakończeniu incydentu Kierownik incydentu informuje wszystkich dotychczasowych adresatów o przywróceniu normalnej pracy.

Incydenty poważne wymagają zawiadomienia organu nadzoru, czyli organ nadzoru. Zawiadomienia przekazuje się w ustalonych terminach, a ich treść jest weryfikowana pod kątem kompletności i spójności z innymi informacjami przekazywanymi przez Bank.

- 9.19. Ocena obowiązku zawiadomienia. Radca prawny wraz z Jednostką zgodności ocenia, czy incydent spełnia kryteria incydentu poważnego, i zapisuje wynik oceny w karcie incydentu.

- 9.20. Zawiadomienie wstępne. Zawiadomienie wstępne w formularzu F-BEZ-06 przekazuje się w terminie 6 godzin od zaklasyfikowania incydentu jako poważnego.
- 9.20.1. Zawiadomienie wstępne zawiera dane Banku, datę wykrycia, ogólny opis incydentu, wstępną ocenę skutków i informację o podjętych działaniach.
- 9.20.2. Brak pełnych informacji nie uzasadnia opóźnienia; informacje brakujące zawiadomienie wskazuje i uzupełnia się je w kolejnych etapach.
- 9.21. Zawiadomienie pośrednie. Aktualizację zawiadomienia przekazuje się w terminie 72 godzin od zawiadomienia wstępnego albo wcześniej, jeżeli zmienia się istotnie ocena skutków.
- 9.22. Zawiadomienie końcowe. Raport końcowy zawierający analizę przyczyn źródłowych i podjęte środki naprawcze przekazuje się w terminie 1 miesiąca od zakończenia czynności związanych z usunięciem skutków incydentu.

10. Opis postępowania — zabezpieczenie dowodów, przywrócenie działania i przegląd

- 10.1. Zasady zabezpieczania materiału dowodowego. Materiał dowodowy zabezpiecza się w sposób, który umożliwia wykazać jego autentyczność i nienaruszalność. Czynności wykonują wyłącznie osoby wyznaczone przez kierownika incydentu.
- 10.1.1. Przed każdą czynnością zmieniającą stan systemu wykonuje się kopię logów, obraz dysku lub zrzut pamięci, a dla każdej kopii oblicza się sumę kontrolną.
- 10.1.2. Oryginały dowodów przechowuje się w oznaczonym, zabezpieczonym miejscu; analizę prowadzi się na kopiach.
- 10.1.3. Każde przekazanie dowodu odnotowuje się w protokole według formularza F-BEZ-04 (łańcuch dowodowy): data, godzina, osoba przekazująca, osoba przyjmująca, cel.
- 10.2. Rodzaje zabezpieczanych danych. Zabezpiecza się zwłaszcza:
- 10.2.1. logi systemowe, aplikacyjne, sieciowe i uwierzytelniania z okresu przynajmniej 13 miesięcy wstecz — o ile taki okres jest dostępny;
- 10.2.2. obrazy dysków i zrzuty pamięci zainfekowanych stacji i serwerów;
- 10.2.3. wiadomości phishingowe wraz z nagłówkami technicznymi;
- 10.2.4. zapisy rozmów telefonicznych i korespondencję z osobami zgłaszającymi;
- 10.2.5. zapisy z monitoringu wizyjnego i rejestry wejść w przypadku incydentów fizycznych.
- 10.3. Wstrzymanie usuwania danych. Na czas obsługi incydentu i do zamknięcia wszystkich związanych z nim postępowań Jednostka informatyki wstrzymuje automatyczne usuwanie logów i kopii objętych incydemtem (blokada prawna na wniosek Jednostki prawnej).
- 10.4. Ochrona danych w materiale dowodowym. Materiał dowodowy obejmuje często dane osobowe i tajemnicę bankową. Dostęp do niego mają wyłącznie osoby, które go potrzebują do obsługi incydentu; dostęp rejestruje się, a przekazanie materiału poza Bank wymaga zgody Jednostki prawnej.
- 10.5. Plan przywrócenia. Kierownik incydentu wraz z Jednostką informatyki i Jednostką

- ciągłości ustala kolejność przywracania usług, opierając się na priorytetach określonych w planie ciągłości działania i wartościach RTO oraz RPO. Priorytet mają usługi umożliwiające Klientom dostęp do środków i realizację płatności.
- 10.6. Przywrócenie z kopii. Przywracanie systemów z kopii zapasowych poprzedza sprawdzenie, że kopie nie zostały zainfekowane. Systemy, które były przejęte, przywraca się z zaufanych, zweryfikowanych źródeł, nigdy przez proste usunięcie śladów.
- 10.6.1. Przed uruchomieniem systemu wykonuje się skanowanie antywirusowe i weryfikację integralności konfiguracji.
- 10.6.2. Wszystkie hasła, klucze i certyfikaty związane z przywracanym systemem są zmieniane.
- 10.6.3. System włącza się najpierw w trybie ograniczonym, z podwyższonym monitoringiem.
- 10.7. Weryfikacja poprawności danych. Jednostka operacji porównuje stan rachunków i rozliczeń z danymi sprzed incydentu, ustala operacje wykonane w trakcie awarii oraz koryguje wszelkie nieprawidłowe księgowania. Korekty dokonuje się przez zapisy odwracające, z odniesieniem do numeru incydentu.
- 10.8. Skutki finansowe dla Klientów. Jeżeli w wyniku incydentu doszło do nieautoryzowanych transakcji na rachunkach Klientów, Bank zwraca kwotę nieautoryzowanej transakcji do końca następnego dnia roboczego po stwierdzeniu lub zgłoszeniu takiej transakcji, chyba że istnieją uzasadnione i udokumentowane podstawy podejrzenia oszustwa po stronie Klienta — o czym zawiadamia się właściwy organ. Zasady te wynikają z przepisów o usługach płatniczych — zob. ustawa z dnia 19 sierpnia 2011 r. o usługach płatniczych (Dz. U. 2024 poz. 30).
- 10.9. Zakończenie przywracania. Kierownik incydentu zamyka fazę przywracania po łącznym spełnieniu warunków:
- 10.9.1. usługi działają stabilnie w uzgodnionym oknie obserwacji;
- 10.9.2. przyczyna incydentu została usunięta lub skutecznie zneutralizowana;
- 10.9.3. dotknięci Klienci zostali poinformowani, a ich środki zabezpieczone;
- 10.9.4. wszystkie wymagane zawiadomienia zostały przekazane.
- 10.10. Zamknięcie incydentu. Incydent zamyka dyżurny Jednostki bezpieczeństwa po akceptacji kierownika incydentu, uzupełniając Rejestr o datę i godzinę zakończenia, ostateczny poziom ważności, przyczynę źródłową i wartość strat.
- 10.11. Przegląd po incydencie. Dla każdego incydentu o poziomie wysokim lub krytycznym oraz dla każdego incydentu, który spowodował wyjątkowe skutki, Jednostka bezpieczeństwa wykonuje przegląd w terminie 10 dni od zamknięcia incydentu.
- 10.11.1. W przeglądzie biorą udział kierownik incydentu, członkowie Zespołu i przedstawiciele jednostek, których incydent dotyczył; spotkanie prowadzi osoba niezwiązana bezpośrednio z obsługą incydentu.
- 10.11.2. Przegląd ma charakter wyjaśniający, a nie wskazujący winnych; jego celem jest ustalenie, co zadziało, a co nie.
- 10.12. Zakres przeglądu. W przeglądzie bada się:
- 10.12.1. przyczynę źródłową i czynniki, które umożliwiły incydent;

- 10.12.2. skuteczność wykrycia, czyli czas od początku incydu do jego wykrycia;
- 10.12.3. skuteczność reakcji: czasy klasyfikacji, ograniczenia skutków i przywrócenia usług w porównaniu z wymaganiami;
- 10.12.4. jakość komunikacji z Klientami, kierownictwem i podmiotami zewnętrznymi oraz dotrzymanie terminów zawiadomień;
- 10.12.5. kompletność dokumentacji i materiału dowodowego.
- 10.13. Raport z przeglądu. Wyniki przeglądu opisuje się w raporcie według formularza F-BEZ-05, który w ciągu 7 dni od przeglądu zatwierdza dyrektor Jednostki bezpieczeństwa. Raport o incydencie krytycznym przekazuje się Zarządowi.
- 10.14. Wnioski i zalecenia. Z przeglądu wynikają zalecenia z przypisanymi właścicielami i terminami. Zalecenia wprowadza się do wspólnego planu działań, a ich realizację monitoruje Jednostka zgodności; termin realizacji zaleceń nie powinien przekraczać 90 dni od zatwierdzenia raportu, chyba że Jednostka bezpieczeństwa zatwierdzi inny, uzasadniony termin.
- 10.15. Wykorzystanie wniosków. Wnioski z przeglądu wykorzystuje się do aktualizacji reguł systemu SIEM, scenariuszy ćwiczeń, szkoleń pracowników, planów ciągłości działania, ocen dostawców oraz niniejszej procedury.

Przywracanie działania systemów odbywa się w kolejności wynikającej z ich krytyczności dla Banku i klientów. Kolejność ustala Kierownik incydu na podstawie analizy wpływu na działalność, z uwzględnieniem zależności technicznych.

- 10.16. Ustalenie kolejności przywracania.
 - 10.16.1. W pierwszej kolejności przywraca się systemy niezbędne do realizacji płatności i autoryzacji transakcji klientów oraz systemy bezpieczeństwa.
 - 10.16.2. W drugiej kolejności przywraca się kanały obsługi klientów: bankowość elektroniczną i aplikację mobilną, a następnie systemy placówek.
 - 10.16.3. W ostatniej kolejności przywraca się systemy wspierające, takie jak raportowe i analityczne.
- 10.17. Warunki przywrócenia. System można ponownie udostępnić dopiero po spełnieniu wszystkich poniższych warunków:
 - 10.17.1. przyczyna incydu została usunięta albo skutecznie ograniczona, co potwierdził Zespół;
 - 10.17.2. system został przetestowany pod kątem poprawności działania i integralności danych;
 - 10.17.3. dostęp do systemu zostały sprawdzone, a podejrzane konta zlikwidowane;
 - 10.17.4. właściciel systemu i Kierownik incydu zatwierdzili przywrócenie na piśmie.
- 10.18. Stopniowe udostępnianie. Po przywróceniu system przez pierwsze godziny podlega wzmożonemu monitorowaniu, a o wszelkich anomaliach niezwłocznie informuje się Kierownika incydu.

Odtwarzanie danych z kopii zapasowych jest jednym z podstawowych sposobów przywrócenia działania po incydencie. Zasady wykonywania i przechowywania kopii są określone w odrębnych dokumentach; poniższe zasady dotyczą postępowania w trakcie

incydentu.

- 10.19. Wybór punktu odtworzenia. Właściciel systemu proponuje punkt odtworzenia, uwzględniając moment rozpoczęcia incydentu i dopuszczalną utratę danych.
 - 10.19.1. Wybiera się najpóźniejszy punkt sprzed rozpoczęcia incydentu, co do którego istnieje pewność, że nie zawiera złośliwego oprogramowania ani zmian dokonanych przez sprawcę.
 - 10.19.2. Jeżeli moment rozpoczęcia incydentu nie jest znany, odtwarzanie rozpoczyna się od testowania kolejnych, coraz starszych kopii.
- 10.20. Odtworzenie w środowisku odizolowanym. Dane odtwarza się najpierw w środowisku testowym, w którym weryfikuje się ich kompletność i integralność.
- 10.21. Uzgodnienie danych. Jednostka operacji uzgadnia salda i transakcje z okresu między punktem odtworzenia a chwilą incydentu, na podstawie dzienników, potwierdzeń kanałów płatniczych i dokumentów źródłowych.
- 10.22. Rejestr odtworzenia. Z odtworzenia danych sporządza się protokół, który zawiera datę, zakres, użyte kopie, wyniki weryfikacji oraz osoby odpowiedzialne.
- 10.23. Rekuncylacja po incydencie. Po przywróceniu systemów Jednostka operacji wykonuje rekuncylację operacji dokonanych w okresie incydentu.
 - 10.23.1. porównuje salda rachunków Klientów z zapisami w systemie centralnym i w systemach rozliczeniowych;
 - 10.23.2. identyfikuje operacje zdublowane, utracone lub zaksięgowane z błędną datą;
 - 10.23.3. przygotowuje listę korekt wraz z uzasadnieniem i przekazuje ją do akceptacji kierownika incydentu;
 - 10.23.4. po wykonaniu korekt sporządza protokół z rekuncylacji, który dołącza się do dokumentacji incydentu.
- 10.24. Odsetki i opłaty. Gdy w wyniku błędu Klientowi naliczono opłaty lub odsetki, które nie byłyby naliczone w braku incydentu, Bank je koryguje z urzędu, bez konieczności składania wniosku przez Klienta.

11. Testy i ćwiczenia

Skuteczność procedury sprawdza się w praktyce poprzez regularne testy i ćwiczenia. Ich harmonogram na dany rok zatwierdza dyrektor Jednostki bezpieczeństwa do końca stycznia.

- 11.1. Testy planów reagowania. Plany reagowania na incydenty i plany odtwarzania systemów testuje się raz w roku. Test obejmuje co najmniej scenariusze: awarii systemu centralnego, ataku szyfrującego dane i niedostępności kluczowego dostawcy.
- 11.2. Ćwiczenia stołowe. Zespół uczestniczy w ćwiczeniach stołowych dwa razy w roku. W ćwiczeniu omawia się wymyślony scenariusz incydentu, role członków Zespołu, decyzje i komunikaty; z ćwiczenia sporządza się krótką notatkę z wnioskami.
- 11.3. Ćwiczenia praktyczne. Przynajmniej raz w roku wykonuje się ćwiczenie praktyczne z użyciem środowiska testowego lub kontrolowanej symulacji ataku, w którym sprawdza się działanie narzędzi wykrywania, kanałów powiadamiania i czasy reakcji.
- 11.4. Ocena wyników. Wyniki testów i ćwiczeń ocenia się według kryteriów: dotrzymanie

czasów reakcji, kompletność powiadomień, poprawność decyzji oraz jakość dokumentacji. Stwierdzone nieprawidłowości traktuje się jak zalecenia po incydencie.

Poza ćwiczeniami organizacyjnymi Bank przeprowadza testy techniczne, które sprawdzają, czy mechanizmy wykrywania i reagowania działają zgodnie z założeniami.

- 11.5. Testy penetracyjne. Niezależny zespół, zewnętrzny lub wewnętrzny, wykonuje kontrolowane próby włamania do wybranych systemów, a zakres testów i zasady ich prowadzenia określa pisemne zlecenie.
 - 11.5.1. Zlecenie wskazuje systemy objęte testem, dozwolone techniki, okno czasowe oraz osoby kontaktowe, które mogą w każdej chwili przerwać test.
 - 11.5.2. Wyniki testów przedstawia się w raporcie z podziałem ustaleń według krytyczności i zaleceniem sposobu naprawy.
- 11.6. Testy wykrywania. Jednostka bezpieczeństwa przeprowadza kontrolowane symulacje typowych ataków i sprawdza, czy system monitorowania wygenerował alert oraz czy analityk odpowiednio na niego zareagował.
- 11.7. Kampanie sprawdzające czujność pracowników. Co najmniej raz w roku wysyła się pracownikom symulowane wiadomości wyłudzające dane i bada, ilu pracowników je otworzyło, kliknęło w odnośnik lub zgłosiło.
 - 11.7.1. Pracownicy, którzy ulegli symulowanej wiadomości, otrzymują natychmiast materiał szkoleniowy, a nie są karani.
 - 11.7.2. Wyniki prezentuje się w sposób zbiorczy, bez wskazywania osób.
- 11.8. Usuwanie podatności. Podatności wykryte w testach usuwa się w terminach zależnych od ich krytyczności, a status usuwania podlega nadzorowi Jednostki bezpieczeństwa.
- 11.9. Scenariusze ćwiczeń. Scenariusze ćwiczeń przygotowuje Jednostka bezpieczeństwa w oparciu o rzeczywiste zagrożenia i wnioski z incydentów. Każdy scenariusz opisuje:
 - 11.9.1. cel ćwiczenia i oczekiwane zachowania uczestników;
 - 11.9.2. przebieg zdarzeń w czasie, w tym momenty podawania uczestnikom nowych informacji;
 - 11.9.3. role uczestników oraz obserwatorów;
 - 11.9.4. kryteria oceny wykonania ćwiczenia.
- 11.10. Zakres tematyczny. W cyklu rocznym ćwiczenia obejmują przynajmniej: atak szyfrujący dane, wyciek danych osobowych, niedostępność systemu centralnego, przejęcie konta uprzywilejowanego, incydent u kluczowego dostawcy oraz kampanię wyłudzącą dane Klientów.

Skuteczna obsługa incydentu wymaga sprawnej łączności z osobami, które mogą zostać do niej wezwane. Gotowość kanałów łączności sprawdza się regularnie, niezależnie od ćwiczeń scenariuszowych.

- 11.11. Test wezwania. Co kwartał Dyżurny przeprowadza próbne wezwanie członków Zespołu, wysyłając wiadomość i wykonując połączenia na numery z listy kontaktów alarmowych.
 - 11.11.1. Mierzy się czas, w jakim potwierdziły odbiór poszczególne osoby; za prawidłowy uznaje się wynik, w którym co najmniej 90% wezwanych potwierdziło odbiór

w ciągu piętnastu minut.

- 11.11.2. Osoby, które nie potwierdziły odbioru, są kontaktowane przez przełożonego w celu wyjaśnienia przyczyn i aktualizacji danych.
- 11.12. Test kanałów zapasowych. Raz na pół roku sprawdza się działanie zapasowych kanałów łączności, w tym komunikatora poza infrastrukturą Banku i telefonów satelitarnych lub służbowych telefonów zapasowych.
- 11.13. Test pokoju operacyjnego. Raz w roku sprawdza się, czy wirtualny pokój operacyjny incydentu można uruchomić w ciągu godziny, czy ma dostęp do niego komplet uprawnionych osób oraz czy rejestruje wszystkie wpisy.
- 11.14. Wyniki testów. Wyniki testów łączności zapisuje się w rejestrze ćwiczeń, a zauważone nieprawidłowości usuwa się bez zbędnej zwłoki.

12. Przypadki szczególne

Poniżej opisano sytuacje, w których postępowanie według zasad ogólnych wymaga modyfikacji. Pozostałe postanowienia procedury stosuje się odpowiednio.

Zasady wspólne dla przypadków szczególnych:

- 1) w przypadku wątpliwości co do tego, który tryb obowiązuje, stosuje się tryb bardziej rygorystyczny;
 - 2) kierownik incydentu może odstąpić od kolejności czynności określonej w procedurze, jeżeli wymaga tego ochrona Klientów lub ich środków; odstąpienie i jego uzasadnienie odnotowuje w dzienniku zdarzeń;
 - 3) w przypadku jednoczesnego wystąpienia kilku incydentów priorytet nadaje się według poziomu ważności, a przy tym samym poziomie — według liczby dotkniętych Klientów.
- 12.1. Awaria systemu płatności lub rozliczeń. W razie awarii, która uniemożliwia realizację przelewów lub rozliczeń, Jednostka operacji:
 - 12.1.1. ustala listę zleceń nierealizowanych, w tym zleceń natychmiastowych oraz z terminami, których niedotrzymanie powoduje dla Klienta dodatkowe skutki;
 - 12.1.2. po przywróceniu systemu realizuje zlecenia w kolejności ich złożenia, z uwzględnieniem priorytetów;
 - 12.1.3. informuje Jednostkę zgodności o terminie wznowienia, aby oceniła, czy incydent podlega zgłoszeniu organowi nadzoru jako incydent poważny.
 - 12.2. Skutki dla Klientów. Opłaty i odsetki naliczone Klientom w wyniku opóźnienia spowodowanego awarią Bank zwraca z urzędu.

Incydent z udziałem pracownika, w szczególności podejrzenie nadużycia lub celowego działania na szkodę Banku, wymaga zachowania szczególnej poufności i ostrożności w ocenie faktów, aby chronić dobre imię osoby, której zdarzenie dotyczy.

- 12.3. Ograniczenie kręgu osób. Informacje o zdarzeniu przekazuje się wyłącznie osobom, które muszą je znać, a ich listę prowadzi Kierownik incydentu.
- 12.4. Zabezpieczenie dowodów. Jednostka bezpieczeństwa zabezpiecza dane i urządzenia, których dotyczy podejrzenie, w sposób niewzbudzający niepotrzebnej uwagi, ale zgodny z zasadami opisanymi w niniejszej procedurze.

- 12.4.1. Czynności wymagające wglądu w korespondencję lub dane pracownika wykonuje się wyłącznie w granicach dopuszczonych prawem i regulaminem pracy.
- 12.4.2. Zakres analizowanych danych ogranicza się do tych, które są niezbędne dla wyjaśnienia sprawy.
- 12.5. Udział Jednostki kadr. Jednostka kadr doradza w zakresie konsekwencji pracowniczych; decyzje w tej sprawie podejmuje się dopiero po zakończeniu analizy faktów.
- 12.6. Zawiadomienie organów. Jeżeli istnieje uzasadnione podejrzenie przestępstwa, zawiadomienie organów ścigania składa Zarząd na wniosek radcy prawnego.
- 12.7. Podejrzenie nadużycia przez pracownika. Gdy podejrzenie dotyczy pracownika Banku lub osoby mającej dostęp do jego systemów, obsługę incydentu prowadzi się z zachowaniem szczególnej poufności.
 - 12.7.1. Informacje o podejrzeniu otrzymują jedynie osoby, które muszą je znać do przeprowadzenia czynności.
 - 12.7.2. Jednostka kadr i Jednostka prawna uczestniczą w czynnościach wobec pracownika, dbając o zgodność z przepisami prawa pracy i ochrony danych osobowych.
 - 12.7.3. Dostęp pracownika do systemów można ograniczyć lub zawiesić po zabezpieczeniu śladów jego aktywności.
 - 12.7.4. Pracownik ma prawo do przedstawienia wyjaśnień, a decyzje wobec niego podejmuje się na podstawie całości ustaleń, nie wyłącznie danych z systemów monitorujących.

13. Kontrola i nadzór

Stosowanie procedury podlega kontroli w ramach systemu kontroli wewnętrznej Banku, zgodnie z wymogami wynikającymi z przepisów prawa bankowego — zob. ustawa z dnia 29 sierpnia 1997 r. – Prawo bankowe (Dz. U. 2024 poz. 1646).

- 1. Kontrola obejmuje:
 - 1) kontrolę funkcjonalną, czyli bieżącą weryfikację kompletności wpisów w Rejestrze przez Jednostkę bezpieczeństwa (co miesiąc);
 - 2) kontrolę Jednostki zgodności, czyli ocenę dotrzymywania terminów zawiadomień dla organów zewnętrznych (co kwartał);
 - 3) audyt wewnętrzny, czyli niezależną ocenę adekwatności i skuteczności procedury, prowadzoną przez Jednostkę audytu zgodnie z planem audytów.
- 2. Wskaźniki monitorowane w ramach nadzoru nad procedurą to w szczególności:
 - 1) liczba incydentów w podziale na poziomy ważności i kategorie;
 - 2) średni czas wykrycia, klasyfikacji i zamknięcia incydentu;
 - 3) odsetek incydentów, w których dotrzymano czasu pierwszej reakcji;
 - 4) odsetek zawiadomień przekazanych w terminie;
 - 5) liczba przeterminowanych zaleceń po incydentach.

Jednostka bezpieczeństwa przedstawia Zarządowi kwartalne sprawozdanie z incydentów,

a w razie incydentu krytycznego — niezwłoczną informację. Nieprawidłowości stwierdzone w kontroli są podstawą do zaleceń, których wykonanie monitoruje Jednostka zgodności.

Przestrzeganie procedury podlega kontroli na trzech poziomach: bieżącej kontroli funkcjonalnej wykonywanej przez Kierownika incydentu, kontroli prowadzonej przez Jednostkę bezpieczeństwa oraz niezależnego audytu.

13.1. Kontrola bieżąca. Kierownik incydentu sprawdza kompletność dokumentacji podczas incydentu i przed jego zamknięciem.

13.1.1. Sprawdza się, czy zarejestrowano wszystkie istotne zdarzenia i decyzje, czy dochowano terminów oraz czy powiadomiono wszystkie osoby wskazane w macierzy komunikacji.

13.1.2. Braki w dokumentacji uzupełnia się przed zamknięciem; zamknięcie incydentu z brakami jest dopuszczalne wyłącznie za zgodą Jednostki bezpieczeństwa.

13.2. Kontrola jednostki. Jednostka bezpieczeństwa co kwartał analizuje próbkę incydentów zamkniętych w danym okresie, obejmującą co najmniej każdy incydent krytyczny i wysoki oraz 10% pozostałych.

13.3. Wnioski z kontroli. Wyniki kontroli przedstawia się kierownikom jednostek, których dotyczyły stwierdzone nieprawidłowości, a ci przedstawiają plan naprawczy z terminami.

Dzienniki zdarzeń systemów są podstawowym źródłem informacji o incydentach i dowodem w postępowaniach, dlatego ich gromadzenie, ochrona i przechowywanie podlegają szczególnemu nadzorowi.

13.4. Zakres rejestrowania. Dzienniki obejmują co najmniej logowania, zmiany uprawnień, dostęp do danych klientów, dyspozycje płatnicze oraz czynności administracyjne.

13.5. Ochrona dzienników. Dzienniki przesyła się na bieżąco do centralnego systemu SIEM-PRZYKŁAD, w którym są chronione przed zmianą i usunięciem.

13.5.1. Dostęp do dzienników mają wyłącznie wyznaczeni pracownicy Jednostki bezpieczeństwa, a każde ich użycie jest rejestrowane.

13.5.2. Administratorzy systemów nie mają możliwości modyfikowania dzienników własnych systemów.

13.6. Okres przechowywania. Dzienniki przechowuje się przez okres 13 miesięcy, a dzienniki dotyczące incydentów — przez okres przechowywania dokumentacji incydentu.

13.7. Kontrola kompletności. Co miesiąc Jednostka bezpieczeństwa sprawdza, czy nie występują luki w ciągłości dzienników, a stwierdzone luki wyjaśnia z właścicielem systemu.

Zarząd i organy nadzorcze Banku otrzymują regularne informacje o stanie bezpieczeństwa i obsłudze incydentów. Jednostka bezpieczeństwa przygotowuje je według jednolitego wzoru, aby umożliwić porównanie okresów.

13.8. Raport kwartalny. Raport zawiera:

13.8.1. liczbę i rodzaje incydentów w podziale na klasyfikacje;

13.8.2. omówienie incydentów krytycznych i wysokich, w tym przyczyny i podjęte

działania;

13.8.3. wskaźniki skuteczności obsługi incydentów;

13.8.4. stan realizacji zaleceń z przeglądów i ćwiczeń oraz działania opóźnione.

13.9. Raport roczny. Raz w roku Jednostka bezpieczeństwa przedstawia Zarządowi ocenę adekwatności procesu obsługi incydentów, zawierającą wnioski dotyczące zasobów, narzędzi i szkoleń.

13.10. Informacje nadzwyczajne. O każdym incydencie krytycznym Zarząd jest informowany niezwłocznie, niezależnie od cyklu raportowania.

13.11. Archiwizacja raportów. Raporty przechowuje się wraz z dokumentacją incydentów przez okres 10 lat.

14. Dokumentacja i archiwizacja

Dokumentację incydentu tworzą: wpis w Rejestrze, karta incydentu (F-BEZ-02), dziennik zdarzeń z pokoju operacyjnego, protokoły zabezpieczenia dowodów (F-BEZ-04), kopie zawiadomień i korespondencji z organami zewnętrznymi oraz raporty z przeglądu (F-BEZ-05).

Dokumentację przechowuje się w następujący sposób:

- 1) w postaci elektronicznej, w systemie zgłoszeń i w repozytorium dokumentów Jednostki bezpieczeństwa, z dostępem ograniczonym do osób uprawnionych;
- 2) przez okres 10 lat od zamknięcia incydentu, a w przypadku toczących się postępowań — do ich prawomocnego zakończenia;
- 3) z zabezpieczeniem przed zmianą — poprawki wpisów dokonuje się przez dopisek, bez usuwania poprzedniej treści.

Po upływie okresu przechowywania dokumentację niszczy się w sposób uniemożliwiający jej odtworzenie, za zgodą Jednostki prawnej, a protokół zniszczenia dołącza się do ewidencji dokumentów. Dokumentacja zawierająca tajemnicę bankową może być udostępniona jedynie na zasadach określonych w przepisach prawa bankowego.

Dane osobowe Klientów wykorzystuje się wyłącznie w zakresie niezbędnym do realizacji zadań opisanych w procedurze, zgodnie z przepisami o ochronie danych osobowych (zob. ustawa z dnia 10 maja 2018 r. o ochronie danych osobowych (Dz. U. 2019 poz. 1781)) oraz z zasadą minimalizacji danych.

Pracownik wykonujący czynności objęte procedurą jest obowiązany:

- 1) zabezpieczać dokumenty i dane przed dostępem osób nieupoważnionych;
- 2) nie udostępniać danych poza Bank bez podstawy prawnej;
- 3) niezwłocznie zgłaszać każde podejrzenie naruszenia ochrony danych: inspektorowi ochrony danych (Inspektor Ochrony Danych) oraz jednostce bezpieczeństwa (Departament Bezpieczeństwa).

Wnioski osób, których dane dotyczą, przekazuje się do inspektora ochrony danych (Inspektor Ochrony Danych, iod@bank.example); odpowiedź jest udzielana bez zbędnej

zwłoki, nie później niż w terminie miesiąca od dnia otrzymania wniosku.

15. Postanowienia końcowe

Procedura wchodzi w życie z dniem 1 marca 2024 r. i obowiązuje wszystkich pracowników Banku. Z tym dniem traci moc poprzednia wersja procedury obsługi incydentów.

Właścicielem procedury jest Departament Bezpieczeństwa, który przegląda jej treść przynajmniej raz w roku oraz po każdym incydencie krytycznym i po każdej zmianie przepisów lub wytycznych organu nadzoru wpływającej na jej treść.

Załączniki stanowią nierozdzielną część procedury. Wzory formularzy wskazanych w procedurze udostępnia właściciel procedury w repozytorium dokumentów wewnętrznych.

Zmiany procedury wprowadza się w trybie przewidzianym dla jej pierwotnego przyjęcia. Projekt zmiany przygotowuje właściciel procedury, a opiniuje Departament Zgodności oraz, w razie potrzeby, Departament Prawny.

Każda zmiana musi zawierać:

- 1) wskazanie nowej wersji i daty jej wejścia w życie;
- 2) zwięzły opis zmienionych postanowień wraz z uzasadnieniem;
- 3) wzmiankę o konieczności przeszkolenia pracowników.

Poprzednie wersje archiwizuje się i udostępnia na żądanie komórki ds. zgodności (Departament Zgodności). Pracownicy są informowani o zmianie przed dniem jej wejścia w życie.

Kontakt z Klientem prowadzi się wyłącznie kanałami opisanymi w umowie lub w ustaleniach z Klientem. Dane teleadresowe Banku podawane w korespondencji muszą być zgodne z danymi: adres ul. Przykładowa 1, 00-001 Warszawa, infolinia 800 000 001, strona <https://bank.example>.

W rozmowie z Klientem pracownik:

- 1) przedstawia się i nazwę Banku;
- 2) potwierdza tożsamość Klienta metodą przewidzianą w procedurach bezpieczeństwa;
- 3) nie prosi o podanie haseł, kodów jednorazowych ani numeru PIN.

Sprawy wymagające eskalacji przekazuje się do jednostki właściwej (Departament Obsługi Klienta), a podejrzenia nadużyć — do jednostki bezpieczeństwa (Departament Bezpieczeństwa).

Załącznik nr 1

Macierz klasyfikacji incydentów i wzór karty incyduentu

Macierz pozwala przypisać incydent do poziomu ważności. Gdy incydent spełnia kryteria co najmniej dwóch poziomów, przyjmuje się poziom najwyższy.

Kryterium	Krytyczny	Wysoki	Średni
Liczba dotkniętych Klientów	ponad 1 000 Klientów	od 100 do 1 000 Klientów	mniej niż 100 Klientów
Czas niedostępności usługi	dłużej niż 2 godziny	od 30 minut do 2 godzin	krócej niż 30 minut
Potencjalna strata finansowa	powyżej 500 000,00 zł	powyżej 50 000,00 zł	poniżej 50 000,00 zł
Dane osobowe	ujawnienie danych o wysokim ryzyku lub danych szczególnych kategorii	ujawnienie danych zwykłych bez ryzyka wysokiego	brak ujawnienia
Pierwsza reakcja — do	15 minut	1 godziny	4 godzin
Obsługa	Zespół, powiadomienie członka Zarządu	Zespół, powiadomienie dyrektorów	dyżurny i właściwa jednostka

Incydent o poziomie niskim obsługuje dyżurny w czasie do 2 dni roboczych.

Wzór karty incyduentu

Karta incyduentu (F-BEZ-02) zawiera następujące pola:

Pole	Zawartość
Numer incyduentu	numer przypisany w Rejestrze
Data i godzina wykrycia	moment wykrycia oraz zgłoszenia
Zgłaszający	imię i nazwisko, jednostka, kanał zgłoszenia
Opis zdarzenia	co się stało, jakich systemów lub procesów dotyczy
Kategoria i poziom ważności	kategoria incyduentu, poziom nadany i ewentualne zmiany z godziną
Kierownik incyduentu	imię i nazwisko, skład Zespołu
Skutki	liczba Klientów, wartość operacji, czas niedostępności
Podjęte działania	chronologiczny wykaz czynności z godzinami
Zawiadomienia	adresaci, terminy, numery zawiadomień
Przyczyna źródłowa	ustalona przyczyna lub wzmianka o braku ustaleń
Zalecenia	zalecenia, osoby odpowiedzialne, terminy

Wzór komunikatu dla Klientów

Wzór stanowi punkt wyjścia; treść każdego komunikatu uzgadnia kierownik incydentu z Jednostką komunikacji.

Droży Klienci, informujemy, że w dniu {data} Bank wykrył zdarzenie, które mogło wpłynąć na {rodzaj usługi}. Podjęliśmy działania, aby zabezpieczyć Państwa środki i dane. Prosimy o zmianę hasła do bankowości elektronicznej i o ostrożność wobec wiadomości podszywających się pod Bank. Bank nigdy nie prosi o podanie pełnych danych uwierzytelniających. W razie pytań prosimy o kontakt z infolinią 800 000 001.

Wykaz kontaktów alarmowych

Funkcja	Kontakt
Dyżurny Jednostki bezpieczeństwa	telefon 800 000 040, adres e-mail incydynty@bank.example
Inspektor	adres e-mail iod@bank.example
Infolinia dla Klientów	800 000 001 (codziennie przez całą dobę)
Zastrzeganie instrumentów płatniczych	800 000 002
Dyżurny Jednostki informatyki	numer służbowy zgodny z aktualnym harmonogramem dyżurów
Organ nadzoru	kanał wyznaczony przez organ nadzoru dla zawiadomień o incydentach poważnych

Zestawienie czasów reakcji według klasyfikacji

Klasyfikacja	Czas reakcji	Osoba decydująca
Krytyczna	15 minut	Kierownik incydentu i członek Zarządu
Wysoka	1 godziny	Kierownik incydentu
Średnia	4 godzin	Analitik bezpieczeństwa
Niska	2 dni roboczych	Dyżurny

Czas reakcji liczy się od chwili zaklasyfikowania incydentu albo od chwili podwyższenia jego klasyfikacji.

Załącznik nr 2

Lista kontrolna obsługi incydu

Listę wypełnia kierownik incydu (lub dyżurny — dla incydentów średnich i niskich) i dołącza do karty incydu.

- ☐ Zgłoszenie zarejestrowane w Rejestrze i potwierdzone osobie zgłaszającej.
- ☐ Poziom ważności nadany w ciągu 2 godzin od zgłoszenia.
- ☐ Wyznaczono kierownika incydu; w razie potrzeby powołano Zespół.
- ☐ Otwarto pokój operacyjny i prowadzony jest dziennik zdarzeń.
- ☐ Zabezpieczono materiał dowodowy, a protokół F-BEZ-04 wypełniono.
- ☐ Podjęto działania ograniczające skutki, a ich wpływ na Klientów oceniono.
- ☐ Jednostka zgodności i Inspektor ocenili obowiązki wobec podmiotów zewnętrznych.
- ☐ Zawiadomienie wstępne dla organu nadzoru przekazano w terminie 6 godzin (jeżeli dotyczy).
- ☐ Naruszenie ochrony danych zgłoszono w terminie 72 godzin (jeżeli dotyczy).
- ☐ Klientów poinformowano w terminie 24 godzin (jeżeli dotyczy).
- ☐ Usunięto przyczynę, a usługi przywrócono i zweryfikowano.
- ☐ Skorygowano błędne księgowania i zwrócono nieautoryzowane transakcje.
- ☐ Zawiadomienie pośrednie i raport końcowy przekazano w terminach (jeżeli dotyczy).
- ☐ Przegląd po incydencie przeprowadzono w terminie 10 dni, a zalecenia wpisano do planu działań.
- ☐ Incydent zamknięto w Rejestrze.